Quantitative Phishing Risk Assessment: GlobalTech Inc.

Lab 3: Advanced GRC Phishing Simulation & Quantitative Risk Analysis

Name	Oluwatosin Olajubu
Registration Number	C11/26/CGRCE/217602
Workbook	Lab3_Calculation_Workbook.xlsx

1. Executive briefing

To: Board of Directors, CISO, CFO

From: GRC Risk Analysis Team

Subject: Phishing simulation results, evidence-based exposure estimate and control investment

Bottom line. Our phishing simulation analysis reveals a **CRITICAL risk exposure of $652 million** annually. The "IT Password Reset" campaign showed a 30% credential theft rate, projecting to 600 compromised accounts organization-wide. So we rebuilt the estimate on an event-based model with an explicit annual occurrence assumption. My base-case annualised loss expectancy (ALE) comes out at about **$3.8 million**, with a plausible range of $1 million to $17 million across the assumptions we tested. That is still material, and the case for controls is strong. MFA, an email gateway and awareness training cost about $240,000 in direct spend ($342,000 with employee time), and in my model they remove roughly 97% of the loss. Immediate action is required.

Key findings

Finding	Value	Meaning
Pooled credential submission rate	24.4% (105 of 430)	Roughly one recipient in four gave away a credential
Highest credential rate	Campaign B, 30.0% (95% CI 24.3% to 35.7%)	Significantly above A ($p = 0.022$) and C ($p = 0.008$)
Highest click rate	Campaign C (executives), 75.0%	Executives click most but submit less often (20% of clickers)
Personal data disclosed	27.8% / 33.3% / 66.7% of submitters (A / B / C)	Executive submitters over-disclose most
Base-case ALE (event model)	$3.81 million per year	0.75 expected major breaches a year; 53% chance of at least one
Brief's ALE	$652.5 million	Unsupported; 3.8x payroll

Finding	Value	Meaning
Core control package ROI	about 980% to 1,010% (annual)	Pays back in roughly 10 to 11 months of loss avoided
Break-even	0.113 of a breach per year ($490,000 / $4.35M)	Portfolio breaks even if it removes 15.6% of baseline loss

What this means for the business. First, credential theft is the practical way into the organisation, so the risk sits wherever a stolen password alone is enough. Second, I don't think awareness training can close this gap by itself, because independent trials show only modest effects, so technical controls have to carry the load. Third, executives need their own control set. Their group is small, but their accounts carry the highest impact.

Recommended actions

1. **Q1: enforce MFA across the company ($90,000 plus about $20,000 of enrolment time).** We'd use phishing-resistant authenticators (FIDO2 or passkeys) first for executives, assistants, IT administrators and finance approvers, and number-matched app MFA for everyone else.
2. **Q1: harden the executive group (no extra licence cost).** We'd add out-of-band verification for payment and document requests, plus a briefing built around the Campaign C lure.
3. **Q1/Q2: roll out the email security gateway ($50,000).**
4. **Q1/Q2: run role-based awareness training ($100,000 plus about $82,000 of staff time).** We'd fund it, but We'd treat my modelled 60% benefit as an upper bound and measure what actually happens.
5. **Keep the simulation programme ($25,000) as our measurement tool.** We'd re-test quarterly with a control group to confirm the controls are working.
6. **Hold off on continuous monitoring ($150,000) and behaviour analytics ($75,000).** I couldn't tie either to phishing credential loss with the data supplied, so we'd bring them back as separate business cases.

What we are less sure about. The $4.35 million breach cost, the 25% breach probability and the control effectiveness figures are scenario assumptions from the brief, not verified benchmarks. The annual occurrence rate is my own assumption. The test groups weren't random samples, so carrying their rates over to all 2,000 employees is only indicative. Section 9 has the details.

2. Data, method and assumptions

What we were given [Inputs]. Three campaigns: A "HR Bonus Notification" (100 recipients), B "IT System Password Reset" (250) and C "CEO Urgent Document Review" (80 executives and assistants). The organisation has 2,000 employees on an $85,000 average salary. One major breach costs $4.35 million, with a 25% chance of a major breach if credentials are stolen. Control costs and effectiveness are exactly as the brief states them.

Assumptions I had to add myself (the yellow cells in the workbook).

Assumption	Value	Rationale
Annual rate of occurrence (ARO)	1 successful real-world campaign per lure type per year (sensitivity 0.25 to 4)	The brief gives none; the instructor briefing requires an explicit one

Assumption	Value	Rationale
P(major breach given credentials stolen) applied	Once per credential-theft event, not per account	Accounts from one campaign are correlated; a breach is an organisational event
Impact multiplier	1.0 for A and B; 1.5 for C	Executive access is privileged; judgement, tested 1.0 to 2.0
Employee time	1 hour training; 15 minutes MFA enrolment, at $40.87 per hour ($85,000 / 2,080)	Salary is otherwise unused in the brief
MFA effectiveness planning case	90% (supplied 99.9% shown as upper bound)	Allows for bypass of weaker MFA types
Email gateway effectiveness	20%	Implied by the brief's $130.5M benefit (20% of $652.5M)
Monitoring, analytics, simulation programme	0% credited	No effectiveness supplied

How I did it. For Step 1 I used emails sent as the denominator, as the brief defines it. For the conversion rates I used the previous funnel stage. I calculated ALE as ARO x P(breach per event) x SLE x impact multiplier. Control benefit is baseline ALE x assumed effectiveness, and ROI is (benefit - cost) / cost. Where several controls overlap, I combined them as 1 minus the product of (1 - effectiveness), rather than adding them. For the overall structure I followed NIST SP 800-30 (likelihood x impact) and the quantitative ALE logic used in FAIR-style analysis [9, 13, 14].

3. Phase 1: Basic metric calculations [Phase1_Rates]

Step 1: Fundamental rates (events / emails sent x 100)

Campaign	Open rate	Click-through	Credential submission	Data entry
A	(82/100) = 82.0%	(47/100) = 47.0%	(18/100) = 18.0%	(5/100) = 5.0%
B	(200/250) = 80.0%	(150/250) = 60.0%	(75/250) = 30.0%	(25/250) = 10.0%
C	(72/80) = 90.0%	(60/80) = 75.0%	(12/80) = 15.0%	(8/80) = 10.0%
Pooled (430 emails)	82.3%	59.8%	24.4%	8.8%

Step 2: Efficiency (conversion) metrics with correct denominators

Campaign	Open to click (clicks/opens)	Post-click credential submission (creds/clicks)	Credential to data entry (data/creds)
A	47/82 = 57.3%	18/47 = 38.3%	5/18 = 27.8%
B	150/200 = 75.0%	75/150 = 50.0%	25/75 = 33.3%
C	60/72 = 83.3%	12/60 = 20.0%	8/12 = 66.7%

Campaign	Open to click (clicks/opens)	Post-click credential submission (creds/clicks)	Credential to data entry (data/creds)
Pooled	72.6%	40.9%	36.2%

What we took from this. Click-through isn't credential submission, and that matters here. Campaign C turned almost every open into a click (83.3%), but only 20% of its clickers then submitted credentials. Campaign B got half of its clickers to do so. That makes B the most successful credential-harvesting lure, while C is the best at getting executives to engage, and a click alone still carries malware and drive-by risk. We read data entry as a subset of credential submitters, since the brief says these people "also" entered personal information. On that reading, Campaign C's submitters disclosed personal data two to three times as often as A's and B's. We'd also treat open rates cautiously, because mail-client image pre-fetching inflates them and blocked images understate them.

4. Phase 2: Advanced risk quantification [Phase2_Exposure]

4.1 The brief's method, with corrected arithmetic

We started with the brief's own method. It scales each campaign's credential rate to 2,000 employees, then multiplies by 25% and by the $4.35 million breach cost.

Campaign	Credential rate	Compromised accounts (x 2,000)	"Breaches" (x 25%)	Exposure	Brief stated	Error
A	18%	360	90	$391,500,000	$156,600,000	understated by $234.9M
B	30%	600	150	$652,500,000	$652,500,000	none (arithmetic)
C	15%	300	75	$326,250,000	$104,400,000	understated by $221.85M

Even corrected, we don't think these figures hold up, and we see three problems. First, they treat every compromised account as its own 25% chance of a separate breach. But one attacker steals those credentials through one route, so the 25% makes more sense as a probability per credential-theft event. Second, the brief sets the number of "breaches" equal to the annual rate of occurrence without saying how often such a campaign would succeed in a year. Third, Campaign C targeted 80 executives and assistants, so applying its 15% to all 2,000 staff isn't valid. The relevant scale is about 12 accounts.

4.2 Recommended event-based model

So we switched to an event-based model: ALE = ARO x P(breach per event) x SLE x impact multiplier, with ARO set at 1 per lure type per year.

Campaign (lure)	ARO	P(breach per event)	SLE	Impact multiplier	Expected breaches per year	ALE per year
A: HR bonus	1	25%	$4,350,000	1.0	0.25	$1,087,500

Campaign (lure)	ARO	P(breach per event)	SLE	Impact multiplier	Expected breaches per year	ALE per year
B: IT password reset	1	25%	$4,350,000	1.0	0.25	$1,087,500
C: CEO document	1	25%	$4,350,000	1.5	0.25	$1,631,250
Organisation	3				**0.75**	**$3,806,250**

The annual probability of at least one phishing-originated major breach is 1 - e^(-0.75) = **52.8%**, which replaces the brief's unsupported 93.75%. My base case works out to $1,903 per employee and 2.2% of payroll, against 384% of payroll for the brief's figure. For context, IBM's global averages were $4.44 million in 2025 and $4.99 million in 2026, and phishing-initiated breaches averaged about $4.8 million in 2025 [1, 2]. The brief's $4.35 million is a reasonable scenario value, but it's older than both.

How much the answer moves [Sensitivity]. ALE scales in a straight line with ARO and with P. At ARO 0.25, 1 and 4, my total ALE is $0.95M, $3.8M and $15.2M at $4.35M per breach. At the 2026 IBM global average of $4.99M it's $1.1M, $4.4M and $17.5M, and at the 2026 US average of $11.5M it's about $2.5M, $10.1M and $40.3M [1]. If I use a breach probability of 10% or 40% instead of 25%, the base case moves to $1.5M or $6.1M. The recommendation to put MFA first doesn't change anywhere in that range.

5. Phase 3: Statistical analysis [Stats_CI]

Confidence intervals. we used p ± 1.96 x sqrt(p(1-p)/n), the brief's Wald formula. We also ran the Wilson score interval [10, 11] as a check, since it behaves better with small samples.

Campaign A (the calculation the brief left to me). With p = 0.18 and n = 100, the standard error is sqrt(0.18 x 0.82 / 100) = sqrt(0.001476) = 0.0384. The margin of error is 1.96 x 0.0384 = **0.0753**, so the true rate sits between **10.5% and 25.5%** (Wilson 11.7% to 26.7%).

Campaign B (the brief example, which we checked). We got a standard error of 0.0290, a margin of 0.0568 and a range of 24.3% to 35.7%, which matches the brief. If that rate held across all 2,000 staff, between 486 and 714 accounts would be compromised (point estimate 600).

Campaign	n	Credential rate	Wald 95% CI	Wilson 95% CI	Click rate	Click Wald 95% CI
A	100	18.0%	10.5% to 25.5%	11.7% to 26.7%	47.0%	37.2% to 56.8%
B	250	30.0%	24.3% to 35.7%	24.7% to 36.0%	60.0%	53.9% to 66.1%
C	80	15.0%	7.2% to 22.8%	8.8% to 24.4%	75.0%	65.5% to 84.5%
Pooled	430	24.4%	20.4% to 28.5%	20.6% to 28.7%	59.8%	55.1% to 64.4%

Are the differences real? We ran two-proportion z-tests on the credential rates:

Comparison	Difference	z	p-value (two-sided)	Significant at 5%?
A vs B	18% vs 30% (12 pts)	-2.30	0.022	Yes
B vs C	30% vs 15% (15 pts)	2.65	0.008	Yes
A vs C	18% vs 15% (3 pts)	0.54	0.59	No

Campaign B's credential rate is statistically higher than both A's and C's, so we are putting it first because of the evidence, not rounding. I can't separate A and C on credential rate. On click rate, though, C is significantly higher than both A ($p < 0.001$) and B ($p = 0.015$).

6. Risk assessment matrix [Risk_Matrix]

We scored likelihood from the observed credential rate: 30% or more is 5, 20% to 30% is 4, 10% to 20% is 3, 5% to 10% is 2, and below 5% is 1. We scored impact on target criticality, where 3 is a standard employee credential and 5 is executive or privileged access. That part is my judgement. Risk score is likelihood x impact: CRITICAL is 20 or more, HIGH is 12 to 19 and MEDIUM is 6 to 11.

Campaign	Credential rate	Likelihood	Impact	Score	Rating	Base ALE	Brief method, corrected (upper bound)	Priority	Action
B: IT password reset	30.0%	5	3	15	HIGH	$1.09M	$652.5M	1	MFA enterprise-wide; password-reset verification process; training
C: CEO urgent document	15.0%	3	5	15	HIGH	$1.63M	$326.3M	2	Phishing-resistant MFA for executives; out-of-band approval of payments and documents;

Campaign	Credential rate	Likelihood	Impact	Score	Rating	Base ALE	Brief method, corrected (upper bound)	Priority	Action
									executive briefing
A: HR bonus	18.0%	3	3	9	MEDIUM	$1.09M	$391.5M	3	Role-based training; gateway filtering

Why I ranked them this way. B comes first because it has the highest credential rate (30%, statistically above A and C), a 50% post-click submission rate and the largest exposed population. C ties B on score because its impact is highest, even though its credential rate is lower, and 66.7% of its submitters disclosed personal data. I put it second because its group is small and the fixes (hardware keys, approval procedures) are cheap and targeted. A comes third: its credential rate can't be told apart from C's and its impact is standard. I rated B HIGH rather than the brief's CRITICAL, because that label rested on the unsupported $652.5 million figure. If I raised B's impact to 4 it would become CRITICAL (score 20), but the ordering wouldn't change.

7. Control recommendation table and cost-benefit analysis [Control_Table]

Here is what I found for each control. The baseline ALE is $3,806,250, and cost covers direct spend plus employee time at $40.87 per hour. The effectiveness values are scenario assumptions, not verified benchmarks.

Control	Direct cost	Time cost	Total cost	Assumed effectiveness	Annual risk reduction	Net benefit	ROI	Payback
MFA (supplied 99.9%)	$90,000	$20,433	$110,433	99.9%	$3,802,444	$3,692,011	3,343%	0.35 months
MFA (planning case 90%)	$90,000	$20,433	$110,433	90.0%	$3,425,625	$3,315,192	3,002%	0.39 months
Awareness training	$100,000	$81,731	$181,731	60.0% (click reduction passed to breach likelihood)	$2,283,750	$2,102,019	1,157%	0.95 months

Control	Direct cost	Time cost	Total cost	Assumed effectiveness	Annual risk reduction	Net benefit	ROI	Payback
Email security gateway	$50,000	$0	$50,000	20.0% (implied by brief)	$761,250	$711,250	1,423%	0.79 months
Phishing simulation programme	$25,000	$0	$25,000	0% credited	$0	($25,000)	n/a	measurement tool
Continuous monitoring	$150,000	$0	$150,000	0% credited	$0	($150,000)	n/a	defer
Behaviour analytics	$75,000	$0	$75,000	0% credited	$0	($75,000)	n/a	defer

Fixing the training arithmetic. The brief calls 30% x (1 - 0.60) = 12% a "new click-through rate", but 30% is Campaign B's credential rate. Training acts on clicks, so I took 60% x 0.40 = 24% click-through. With post-click submission unchanged at 50%, the credential rate falls from 30% to 12%, and compromised accounts at organisation scale fall from 600 to 240. That 60% relative reduction is what feeds the benefit.

Combining controls. I combined them by multiplying, not adding. The brief's three controls would add up to 179.9% effectiveness, which is impossible.

Portfolio	Total cost	Combined effectiveness	Annual risk reduction	Net benefit	ROI	Residual ALE
Core: MFA (90%) + training + gateway	$342,163	96.8%	$3,684,450	$3,342,287	977%	$121,800
Core with supplied MFA 99.9%	$342,163	99.97%	$3,805,032	$3,462,869	1,012%	$1,218
Brief's full $490,000 portfolio (MFA 90%)	$592,163	96.8%	$3,684,450	$3,092,287	522%	$121,800

With the core portfolio and my 90% planning case, the annual probability of at least one phishing-originated major breach falls from 52.8% to about 2.4%.

Bonus challenge: break-even. $490,000 / $4,350,000 = **0.113 breaches** per year. Including employee time ($592,163), it's 0.136. In loss terms, the full portfolio has to remove **15.6%** of baseline ALE to break even, and the core package only **9.0%**, against a modelled reduction of 96.8%. That's a wide margin of safety.

How robust is this? MFA breaks even at an ARO of about 0.03 per lure type, which is one successful campaign of each type every 31 to 34 years. Awareness training breaks even at about 0.08 (every 12.6 years) and the gateway at about 0.07 (every 15 years). The ROI magnitudes lean heavily on my ARO assumption.

MFA ROI runs from about 550% at ARO 0.25 with 75% effectiveness to over 13,000% at ARO 4 with 99.9%, so we'd report ranges, not a single figure. The conclusion that MFA comes first holds up either way. we'd add two cautions on the supplied effectiveness figures. Microsoft measured a 99.22% reduction in compromise risk from MFA (98.56% where credentials had leaked), but CISA notes that SMS and push MFA remain open to adversary-in-the-middle phishing and push fatigue. That's why I recommend phishing-resistant methods for executives and administrators [4, 5, 6]. On training, a randomised trial of 19,500 employees found embedded training cut failure rates by only about 1.7%, and large-scale studies report no lasting improvement [7, 8]. I therefore treat 60% as an upper bound.

8. Errors and unsupported assumptions found in the brief [Error_Log]

#	Location	Brief states	Verified / corrected	Issue
1	Step 6, Campaign A	$156,600,000	$391,500,000	Arithmetic error (360 x 0.25 x $4.35M)
2	Step 6, Campaign C	$104,400,000	$326,250,000	Arithmetic error (300 x 0.25 x $4.35M)
3	Step 6, Campaign C	300 accounts at 2,000 scale	about 12 accounts (80 executives)	Group-specific rate applied to whole workforce
4	Step 3	150 breach incidents	0.75 expected breaches per year	Compromised accounts are not independent breaches
5	Step 4B	ALE $652.5M	$3.8M	ARO set equal to a breach count; no annual occurrence assumption
6	Step 4B	$652.5M a year	3.8x annual payroll ($170M)	Fails a plausibility test
7	Step 5	"New click-through rate" 12%	Click-through 60% to 24%; credential rate 30% to 12%	Credential rate mislabelled as click-through
8	Step 8	Overall credential theft rate 22.1%	24.4% (105 / 430)	Calculation error
9	Step 8	Breach probability 93.75%	52.8% (event model)	An expected count is not a probability; no derivation
10	Step 8	Industry averages 15.3%, 18.7%, $285M, 350%	Excluded	No source; unverified benchmarks
11	Step 8	Total risk reduction $587.5M; net $587.01M	$587.25M; $586.76M	Arithmetic; also effects are not additive
12	Step 5	MFA 99.9%	90% planning case	Overstated for phishing; supplied value kept as upper bound

#	Location	Brief states	Verified / corrected	Issue
13	Step 5	Training 60% click reduction	Upper bound	Independent trial evidence is far weaker
14	Step 5	ROI 724,175% and 391,400%	Arithmetic correct; premise flawed	Corrected ROIs are about 1,000% to 3,400%
15	Step 7	Campaign B CI 24.3% to 35.7%	Verified	Correct

9. Limitations

- **These are scenario inputs, not benchmarks.** The $4.35 million breach cost, 25% breach probability and control effectiveness values come from the brief. A single global average isn't a prediction for one organisation, because real loss depends on sector, data held and response speed [1, 2].
- **I assumed the annual occurrence rate.** It's the biggest driver of my result. I've made the assumption and its sensitivity explicit, but I had no incident history to calibrate it against.
- **My control model is simplified.** I applied effectiveness as a proportional cut in breach likelihood and assumed controls combine independently. Real controls overlap and can fail together, for example when MFA is bypassed through the same phishing page.
- **The sampling is weak.** The groups weren't random, the lures differed and there was no untrained control group, so I can't isolate cause. Open rates are unreliable.
- **Some scoring is my judgement.** The impact scores and the executive multiplier are mine, and I left them as editable inputs.
- **Costs follow the brief.** I treated MFA as an annual licence. I haven't included ongoing administration, help-desk load, or phishing-resistant hardware for specific groups. Supply chain, vulnerability exploitation and insider threats sit outside this phishing-credential model.
- **Context.** Phishing initiated about 16% of breaches in 2025, behind stolen credentials (22%) in Verizon's data, and the human element was involved in about 60% of breaches [2, 3]. Phishing controls reduce breach risk but don't eliminate it.

10. References

1. IBM Security and Ponemon Institute (2026) *Cost of a Data Breach Report 2026*. IBM. Available at: https://www.ibm.com/reports/data-breach (Accessed: 31 October 2026).
2. IBM Security and Ponemon Institute (2025) *Cost of a Data Breach Report 2025*. IBM. (Global average USD 4.44 million; phishing the most common initial vector at 16% of breaches, averaging USD 4.8 million.)
3. Verizon (2025) *2025 Data Breach Investigations Report*. Verizon Business. Available at: https://www.verizon.com/business/resources/reports/dbir/ (Accessed: 31 October 2026).
4. Meyer, L.A., Romero, S., Bertoli, G., Burt, T., Weinert, A. and Lavista Ferres, J.M. (2023) 'How effective is multifactor authentication at deterring cyberattacks?', *arXiv*:2305.00945. Available at: https://arxiv.org/abs/2305.00945 (Accessed: 31 October 2026).
5. Weinert, A. (2019) 'Your Pa$$word doesn't matter', *Microsoft Tech Community*, 9 July. Available at https://r.search.yahoo.com/_ylt=A2RSgSGRW.dqyQIAZO5XNyoA;_ylu=Y29sbwNldS13ZXN0LTEEcG9zAzIEdnRpZAMEc2VjA3Ny/RV=2/RE=1794756754/RO=10/RU=https%3a%2f%2fdatu

m.rocks%2fblog%2fyour-password-doesnt-matter/RK=2/RS=lazeQC_EygJTljKgilOdxAXKbkw- (Accessed: 01 November, 2026).
6. Cybersecurity and Infrastructure Security Agency (2022) *Implementing Phishing-Resistant MFA* (fact sheet). Available at: https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf (Accessed: 31 October 2026)
7. Ho, G., Mirian, A., Luo, E., Tong, K., Lee, E., Liu, L., Longhurst, C.A., Dameff, C., Savage, S. and Voelker, G.M. (2025) 'Understanding the efficacy of phishing training in practice', *Proceedings of the IEEE Symposium on Security and Privacy*. doi:10.1109/SP61157.2025.00076
8. Lain, D., Kostiainen, K. and Capkun, S. (2022) 'Phishing in organizations: findings from a large-scale and long-term study', *Proceedings of the IEEE Symposium on Security and Privacy*.
9. National Institute of Standards and Technology (2012) *Guide for Conducting Risk Assessments*, NIST Special Publication 800-30 Revision 1. Gaithersburg, MD: NIST.
10. Wilson, E.B. (1927) 'Probable inference, the law of succession, and statistical inference', *Journal of the American Statistical Association*, 22(158), pp. 209-212.
11. Brown, L.D., Cai, T.T. and DasGupta, A. (2001) 'Interval estimation for a binomial proportion', *Statistical Science*, 16(2), pp. 101-133.
12. Gordon, L.A. and Loeb, M.P. (2002) 'The economics of information security investment', *ACM Transactions on Information and System Security*, 5(4), pp. 438-457.
13. Hubbard, D.W. and Seiersen, R. (2016) *How to Measure Anything in Cybersecurity Risk*. Hoboken, NJ: Wiley.
14. The Open Group (2013) *Risk Taxonomy (O-RT), Version 2.0* (Open FAIR). Reading: The Open Group.